

# POLITIQUE DE **GOUVERNANCE** DES DONNEES

STRATEGIE DE GOUVERNANCE DES DONNEES



| Rapport de diagnostic     |                                  |
|---------------------------|----------------------------------|
| Version                   | 1.0                              |
| Client                    | Etude de cas - SPOTIFY           |
| Date de la version        | 30/09/2026                       |
| Description de la version | Bloc 1 - certification RNCP41993 |
| Modules concernés         | Livrable 2                       |
| Auteur                    | Ronan GUILLOU                    |

## Table des matières

|          |                                          |          |
|----------|------------------------------------------|----------|
| <b>1</b> | <b>Contexte .....</b>                    | <b>3</b> |
| 1.1      | Rappel .....                             | 3        |
| <b>2</b> | <b>Principes de gouvernance .....</b>    | <b>3</b> |
| <b>3</b> | <b>Conformité réglementaire .....</b>    | <b>4</b> |
| 3.1      | RGPD (Union Européenne).....             | 4        |
| 3.2      | CCPA/CPRA (Californie / Etats-Unis)..... | 4        |
| 3.3      | PCI-DSS (Données bancaires).....         | 4        |
| 3.4      | AI Act .....                             | 4        |
| <b>4</b> | <b>Rôles et responsabilité .....</b>     | <b>5</b> |
| 4.1      | Roles et tâches clés.....                | 5        |
| 4.2      | Responsabilités .....                    | 5        |
| <b>5</b> | <b>Conclusion.....</b>                   | <b>6</b> |

# 1 Contexte

## 1.1 Rappel

Le livrable 1 (diagnostic de maturité) a montré une gouvernance des données encore **réactive** : les actions sont déclenchées par les besoins métier ou les obligations légales, sans politique formelle, sans rôles définis à l'échelle de l'entreprise et sans pilotage par des indicateurs.

Ce document y répond en posant les principes de la politique de gouvernance des données et de l'IA de Spotify, ainsi que les rôles associés. Elle repose sur 3 piliers principaux et 1 extension dédiée à l'IA :

- **Qualité et interopérabilité** : des données exactes, complètes, à jour et cohérentes, décrites dans un catalogue et échangées selon des standards communs (data contracts), pour que les équipes les trouvent et les réutilisent facilement.
- **Sécurité** : protection des données contre les accès non autorisés, les pertes et les fuites, par la classification, le moindre privilège (RBAC/ABAC), le chiffrement et la traçabilité des accès.
- **Conformité** : respect du RGPD, du CCPA, de PCI-DSS et des autres réglementations applicables.
- **Extension : gouvernance de l'IA** : traçabilité de l'origine et licéité des données, analyse des biais, reproductibilité, explicabilité, supervision humaine et monitoring des modèles.

## 2 Principes de gouvernance

La politique s'appuie sur les neuf principes du *Governance Principles Guide de Spotify*, organisés autour des trois piliers et de l'extension IA. Deux d'entre eux, la responsabilité et l'amélioration continue, sont transversaux : ils s'appliquent à l'ensemble des piliers.

| Pilier                          | Principe   |
|---------------------------------|------------|
| Qualité et interopérabilité     | 4          |
| Sécurité                        | 3          |
| Conformité                      | 2, 5, 6, 7 |
| Extension IA                    | 9          |
| Tous les piliers (transversaux) | 1, 8       |

### Principes transversaux

- Responsabilité (N°1) : chaque processus de données a un responsable identifié (Data Owners, Data Stewards, DPO). Action : définir les rôles et les responsabilités (section 4).
- Amélioration continue (N°8) : les pratiques évoluent avec la réglementation, la technologie et les besoins de Spotify. Action : revues et mises à jour planifiées du cadre, avec prise en compte des retours.

### Qualité et interopérabilité

- Qualité des données (N°4) : les données collectées sont exactes, complètes et fiables. Prévoir de définir des métriques de qualité, auditer régulièrement, et décrire les jeux de données dans un catalogue avec des data contracts.

### Sécurité

- Sécurité des données (N°3) : les données personnelles et de paiement sont chiffrées et protégées selon les standards les plus élevés (PCI-DSS pour les paiements). Prévoir le contrôle d'accès, le chiffrement ainsi que le protocole de réponse aux violations.

### Conformité

- Transparence (N°2) : la collecte, le stockage et le partage des données personnelles sont clairement expliqués aux utilisateurs. Prévoir la récupération de l'avis de confidentialité détaillés et la gestion du consentement (RGPD, CCPA).
- Conformité (N°5) : traitement licite, avec consentement, et respect des droits des personnes. Prévoir la revue régulière par des audits transversaux face à l'évolution des lois.
- Minimisation (N°6) : seules les données nécessaires à une finalité précise sont collectées. Prévoir les politiques strictes de collecte, proportionnées à l'usage prévu (à documenter).
- Droits des utilisateurs (N°7) : accès, modification, suppression, et opt-out de la collecte ou de la vente. Prévoir de mettre en place les systèmes de traitement des demandes.

### Extension IA

- Usage éthique et approuvé de l'IA (N°9) : toute utilisation de l'IA est transparente, respecte la vie privée et fait l'objet d'une surveillance contre les biais. Prévoir d'intégrer des règles éthiques à chaque projet IA, avec traçabilité de l'origine et de la licéité des données, reproductibilité et explicabilité des modèles, supervision humaine et monitoring en production.

# 3 Conformité réglementaire

Spotify traite des données de résidents européens (RGPD) et californiens (CCPA/CPRA), ainsi que des données de paiement (PCI-DSS). Lorsqu'un pays ou un traitement relève de plusieurs juridictions, **l'exigence la plus contraignante s'applique** : elle sert de socle commun à tous les marchés. Chaque exigence de la checklist est traduite ci-dessous en un contrôle de gouvernance.

## 3.1 RGPD (Union Européenne)

| Compliance Area                     | Exigence                                                                                             | Contrôle de gouvernance                                                                                                    |
|-------------------------------------|------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Principes de traitement des données | Garantir que les données sont traitées de manière licite, loyale et transparente.                    | Registre des traitements avec base légale pour chaque finalité, avis de confidentialité clairs, revue annuelle par le DPO. |
| Droits des utilisateurs             | Les utilisateurs doivent pouvoir accéder à leurs données, les modifier ou les supprimer sur demande. | Processus unique de traitement des demandes, suivi des délais de réponse, exécution par les Data Stewards.                 |
| Gestion du consentement             | Obtenir un consentement explicite et éclairé avant tout traitement de données personnelles.          | Plateforme de gestion du consentement, preuve du consentement (opt-in) conservée, retrait aussi simple que l'acceptation.  |
| Notification des violations         | Notifier l'autorité de contrôle des violations de données sous 72 heures.                            | Protocole de gestion des incidents, registre des violations, exercices de simulation.                                      |
| Délégué à la protection des données | Désigner un DPO pour surveiller la conformité.                                                       | DPO nommé, indépendant, rattaché à la direction, avec rapport régulier au Data Governance Committee.                       |

## 3.2 CCPA/CPRA (Californie / Etats-Unis)

| Compliance Area                    | Exigence                                                                            | Contrôle de gouvernance                                                                   |
|------------------------------------|-------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| Opt-out de la vente de données     | Fournir un mécanisme clair de refus de la vente des données personnelles.           | Lien d'opt-out visible, prise en compte du choix dans tous les systèmes concernés.        |
| Demandes d'accès et de suppression | Permettre aux utilisateurs de demander l'accès à leurs données ou leur suppression. | Même processus de traitement des demandes que pour le RGPD, avec vérification d'identité. |
| Non-discrimination                 | Ne pas pénaliser les utilisateurs qui exercent leurs droits CCPA.                   | Revue des offres et conditions d'accès pour détecter tout traitement différencié.         |

## 3.3 PCI-DSS (Données bancaires)

| Compliance Area                        | Exigence                                                                                      | Contrôle de gouvernance                                                                                                   |
|----------------------------------------|-----------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------|
| Réseau et systèmes sécurisés           | Garantir une infrastructure réseau sécurisée et un pare-feu.                                  | Revue périodique de la configuration réseau, segmentation de l'environnement de paiement.                                 |
| Protection des données de carte        | Protéger les données de carte stockées par chiffrement et stockage sécurisé.                  | Classification « restreint », chiffrement au repos et en transit, gestion des clés.                                       |
| Gestion des vulnérabilités             | Maintenir des systèmes de protection contre les logiciels malveillants et les vulnérabilités. | Correctifs planifiés, antimalware, analyses de vulnérabilités régulières.                                                 |
| Contrôle d'accès                       | Limiter l'accès aux données de carte au personnel autorisé.                                   | Accès au moindre privilège validé par le Data Owner, revue périodique des droits, journaux d'accès. Limite de transferts. |
| Surveillance et tests réguliers        | Mettre en place des contrôles réguliers des mesures de sécurité.                              | Surveillance continue (SIEM), tests d'intrusion, audits périodiques.                                                      |
| Politique de sécurité de l'information | Maintenir une politique de sécurité à jour pour tout le personnel.                            | Politique revue chaque année, diffusion et formation des équipes.                                                         |

## 3.4 AI Act

Chaque système d'IA (recommandation, par exemple) est qualifié par l'AI Risk Owner et le DPO selon son niveau de risque au sens de l'AI Act. S'il est classé à **haut risque**, il doit respecter les exigences de documentation, de gestion des risques et de gouvernance des données.

# 4 Rôles et responsabilité

Les rôles ci-dessous s'appuient sur le *Data Governance Roles Template* de Spotify, qui définit le CDO, le Data Governance Committee, le DPO et le Data Steward. Ils sont complétés par quatre rôles propres à cette politique : Data Owner, Équipe Sécurité et plateforme, Model Owner et AI Risk Owner.

Ces rôles s'organisent selon le modèle **Center of Excellence** (CoE) recommandé pour Spotify : une équipe centrale définit les politiques, les standards et les outils, tandis que les rôles opérationnels (Data Owners, Data Stewards, Model Owners) sont placés au sein des départements métier. Ce modèle allie une gouvernance centralisée cohérente et la souplesse nécessaire à chaque département.

## 4.1 Rôles et tâches clés

| Rôle                                           | Responsabilité principale                                                                                          | Tâches clés                                                                                                                                                                                                                                                                                     |
|------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Chief Data Officer (CDO)</b>                | Piloter la stratégie de gouvernance des données et de l'IA et superviser la gestion des données dans tout Spotify. | <b>Définir</b> les politiques et la stratégie en lien avec les objectifs métier. <b>Garantir</b> l'usage approprié des données, la confidentialité et la conformité dans tous les départements. <b>Aligner</b> la gouvernance avec la <b>direction</b> .                                        |
| <b>Data Governance Committee</b>               | Orienter le cadre de gouvernance et assurer l'alignement dans toute l'organisation.                                | <b>Valider</b> les <b>politiques</b> et <b>processus</b> . Traiter les sujets transverses entre départements. Veiller à <b>l'alignement</b> avec les enjeux <b>juridiques</b> , de conformité et opérationnels.                                                                                 |
| <b>Data Protection Officer (DPO)</b>           | Garantir la conformité aux réglementations de protection des données (RGPD, CCPA). Indépendant, rattaché à la DG.  | <b>Surveiller</b> le respect des lois sur la <b>vie privée</b> . Être <b>l'interlocuteur</b> des autorités de protection des données. <b>Conseiller</b> sur les analyses d'impact (AIPD). Superviser la gestion et la notification des violations.                                              |
| <b>Data Owner (par domaine métier)</b>         | Être responsable d'un domaine de données, de sa valeur, de son usage et de son niveau de sécurité.                 | <b>Classifier</b> les données du domaine. Décider qui y accède ( <b>moindre privilège</b> ). <b>Valider</b> les <b>règles</b> de qualité et les finalités de traitement.                                                                                                                        |
| <b>Data Steward</b>                            | Superviser les pratiques de gestion des données dans un département donné.                                         | Garantir <b>l'exactitude</b> , la <b>cohérence</b> et la <b>fiabilité</b> des données. Mettre en œuvre les améliorations de <b>qualité</b> avec les <b>équipes techniques</b> . Appliquer les <b>politiques</b> de gouvernance et gérer les <b>accès</b> . Exécuter les demandes des personnes. |
| <b>Équipe Sécurité et plateforme (CIO/CTO)</b> | Mettre en œuvre techniquement les contrôles de sécurité et héberger les données.                                   | <b>Chiffrement</b> , gestion des <b>accès</b> , journaux <b>d'audit</b> , <b>supervision</b> . Appliquer les exigences PCI-DSS. Détecter et gérer les <b>incidents</b> .                                                                                                                        |
| <b>Extension IA</b>                            |                                                                                                                    |                                                                                                                                                                                                                                                                                                 |
| <b>Model Owner</b>                             | Être responsable d'un modèle d'IA tout au long de son cycle de vie.                                                | <b>Documenter</b> l'origine et la licéité des données d'entraînement. Assurer la reproductibilité et <b>l'explicabilité</b> . <b>Surveiller</b> les performances et les <b>dérives</b> en production.                                                                                           |
| <b>AI Risk Owner</b>                           | Identifier, évaluer et suivre les risques liés aux systèmes d'IA.                                                  | Qualifier <b>le niveau de risque</b> selon l'AI Act, avec le DPO. Piloter l'analyse des <b>biais</b> . Assurer la <b>supervision</b> humaine et escalader au Committee.                                                                                                                         |

## 4.2 Responsabilités

Voici une mini matrice RACI. Chaque activité **a un seul « A »** (Approuve), c'est-à-dire une seule personne qui répond du résultat final et tranche en cas de désaccord, la responsabilité finale n'est jamais partagée.

| Activité                                                         | CDO | DGC      | DPO      | Data Owner | Data Steward | Sécurité | Model Owner | AI Risk Owner |
|------------------------------------------------------------------|-----|----------|----------|------------|--------------|----------|-------------|---------------|
| Approuver la politique de gouvernance                            | R   | <b>A</b> | C        | C          | I            | C        | I           | C             |
| Classifier les données et décider des accès                      | I   |          | C        | <b>A</b>   | R            | R        |             |               |
| Définir et suivre les règles de qualité                          | I   |          |          | <b>A</b>   | R            | C        |             |               |
| Traiter les demandes des personnes (accès, suppression, opt-out) | I   |          | <b>A</b> | C          | R            | C        |             |               |

|                                                       |     |   |   |   |   |   |     |   |
|-------------------------------------------------------|-----|---|---|---|---|---|-----|---|
| Gérer et notifier une violation de données            | I   | I | A | C | I | R |     |   |
| Documenter et surveiller un modèle d'IA               | I   |   | C |   |   | C | A/R | C |
| Qualifier le risque IA (AI Act) et analyser les biais | I   | I | C | C |   |   | R   | A |
| Revoir la politique et auditer la conformité          | A/R | C | C | I | I | C | I   | C |

Réalise · Approuve / Responsable · Consulté · Informé

## 5 Conclusion

Le diagnostic de maturité avait révélé une gouvernance réactive, sans politique formelle, sans rôles définis à l'échelle de l'entreprise et sans pilotage par des indicateurs. Cette politique apporte une première réponse structurée : elle pose **neuf principes** organisés autour de **trois piliers** (qualité et interopérabilité, sécurité, conformité) et d'une extension dédiée à l'IA, traduit les **14 exigences** de la checklist (RGPD, CCPA, PCI-DSS) en contrôles de gouvernance, et attribue des responsabilités claires grâce au modèle **Center of Excellence** et à la matrice RACI.

Elle n'est toutefois qu'un **cadre** : sa valeur dépendra de sa mise en œuvre. Elle sera déployée par étapes, en commençant par un département pilote, puis complétée par un pilotage par indicateurs, des audits et une veille réglementaire pour inscrire la gouvernance dans une amélioration continue.